# CA/Browser Forum Tracker

Part 5 - Revocation and Transparency

Last updated: 2026-10-25

## About This Report

This is an experimental, AI-driven research project from SRL. SRL is independent, with no outside funding and no sponsors. This tracker is a summarized pull of the public record, kept as a coherent, concise news update. It draws on the CA/Browser Forum's own ballots, mailing lists and published documents, and on the public sources of the browser root programs. An AI model reads those sources and writes the summary, and every statement links to the source it came from. Where two sources disagree, both are reported. AI makes mistakes, so check the linked source before relying on any statement. The tracker is updated each week that the public record shows a change.

Revocation and transparency are the two ways the web recovers from a certificate that should not exist. Revocation withdraws trust from a certificate already issued. Transparency makes every issued certificate public, so that a bad one can be found at all.

Both were tested hard in the eight weeks to 25 October, and hardest in the last one. Section 1 covers revocation, where a key compromise at eMudhra and GoDaddy's finished mass revocation of more than 400,000 certificates both landed in the same week. Section 2 covers Certificate Transparency, where a flood of proof-of-concept certificates forced one operator to close its logs and Let's Encrypt admitted a policy breach. Section 3 covers Merkle Tree Certificates, a design that folds transparency into issuance itself.

## 1. Revocation Mechanisms and Timelines

*Revocation is the part of the certificate system that has never worked well. The industry's answer has been to route around it with shorter certificates, while the deadlines for revoking a bad certificate stay strict.*

### Recent Developments

The sharpest test came from a key compromise. On 17 October the private keys of eight eMudhra intermediate authorities were found to be recoverable, because their ECDSA private scalars were smaller than 256 [1]. Browser-side blocking did the first work. Chrome blocked the keys through its revocation list within two hours of the report, and Mozilla's block was fully distributed within three [2] [3]. eMudhra revoked the eight certificates the next morning for key compromise, and Sectigo revoked its cross-certificates for them on 19 October [1].

The compromise exposed the limits of the authority's own revocation. eMudhra admitted that its revocation lists had been re-signed with the flawed keys, so an attacker holding the keys could have issued a clean list [1]. By 25 October its revocation and status servers were refusing requests from common command-line tools, which became a separate bug [4] [5]. Mozilla then removed the root above the eight on 20 October, and Chrome follows on 27 October, as Part 4

records [1] [2]. Let’s Encrypt’s issuance software gained a check for small ECDSA scalars on 20 October, the first authority-side code response [6].

The largest event by count ended the same week. On 15 October GoDaddy found that 404,607 certificates from its GoDaddy and Starfield hierarchies carried policy information that did not match its own practice statement [7]. The Baseline Requirements gave it five days, to 18 October at 23:45 UTC, and it said on 16 October that it would not make that deadline [8]. By the deadline it had revoked 170,566 certificates and by early on 19 October 227,422 [8]. On 22 October it reported the work complete, with a corrected total of 403,643 certificates, 378,067 revoked and 25,576 expired, leaving none valid [8].

The revocation infrastructure kept drawing problem reports. DigiCert reported a revocation list whose sequence number went backwards and a list published three minutes late, and is moving its schedule to twenty hours [9]. Telekom’s DFN and SwissSign reported lists whose validity ran one second long, a defect the common linters accept [10]. SHECA reported status responder keys with a public exponent of three, which HARICA called practically unrevocable, and revoked every authority under four roots that browsers do not trust [11]. Seven bugs in one week concerned status responder certificate profiles, which looks like one third party’s sweep [10].

Missed deadlines were already a theme in September. The SHA-1 sunset required unexpired subordinate certificates with SHA-1 signatures to be revoked by 15 September [12]. Within three days, GoDaddy, Firmaprofesional, FNMT and DigiCert each had a delayed revocation report open [12] [13]. October then brought thirteen bugs about faulty online status responses between 8 and 13 October [14].

The country-code registry hijacks of early October showed browser-side revocation at work. Chrome blocked the unauthorized certificates for Google properties through CRLSets at once, then worked with the issuers to revoke them for other clients [15]. A community count found 102 certificates from the hijacks, all present in a CRLSet of 10,823 entries [16]. Chrome warned that browser-side blocking may not cover every domain [15].

Let’s Encrypt moved its own lifetimes ahead of the Forum’s schedule. On 7 October it announced that its default certificates will last 64 days from 10 February 2027, down from 90 [17]. Subscribers may choose 45 or six days instead, and no valid certificate will be revoked in the change [17]. Staging switched to 64-day certificates on 14 October [18].

## Current State

The online status protocol is being retired rather than repaired. Let’s Encrypt ended its responder service in August 2025, citing privacy, because the protocol tells the responder which site a user is visiting [19]. HARICA stopped putting responder addresses in new web certificates in March 2026 and expects to shut down its web responders by 4 May 2027 [20]. The IETF published a lightweight status protocol profile for high-volume environments, RFC 9919, in July 2026 [21].

Short lifetimes are the replacement. Let’s Encrypt issued its first six-day certificate in February 2025, and those certificates carry no revocation addresses at all [22]. Renewal is steered by the ACME renewal information protocol, published as RFC 9773 in June 2025, which lets an authority tell clients when to renew [23]. Part 1 covers the Forum’s own lifetime schedule.

Browser revocation summaries differ widely in coverage. Firefox's CRLite has covered 99.84% of certificates visible in transparency logs since August 2025, with about 300 kB of daily updates checked locally [24]. Chrome's CRLSets carry about 1% of all revocations, aimed at high-impact and emergency cases [24]. The eMudhra response used both, and the compromised keys were blocked in every current Firefox and Chrome before the authority had revoked anything [2] [3].

Mass revocation now has a written template. Mozilla merged an illustrative plan template on 23 September for the mass revocation plans its policy requires [25]. It defines a mass revocation event as at least 100 certificates or 1% of an authority's active web certificates [26]. Plans must be tested at least every 12 months [26]. GoDaddy's 403,643 certificates and HARICA's 63,525 in July 2026 are the two largest such events of the year [8] [27].

The meaning of revocation itself is under discussion. SC-107 would count a certificate as revoked once its serial number appears in a revocation list or draws a revoked status response, from 15 February 2027 [28]. It would also set how quickly an authority must judge a problem report [28]. The ballot was still in discussion on 25 October, past its scheduled end, and Part 1 follows it [28].

### Unresolved Conflicts

Two questions sit open. The first is when Mozilla's mass revocation testing became auditable. One Mozilla policy change describes annual tests that revoke 30 random certificates within five days, with audit attestation after 15 April 2026 [29]. Mozilla's template and its earlier guidance date third-party assessment from the audit cycle beginning June 2025 [26] [30]. The current text of the policy's revocation section would settle it.

The second is whether the Forum's revocation deadlines will split. Working group discussions in 2025 proposed separate tracks for breaches of the Baseline Requirements and for deviations from an authority's own policy, with 90 days for the latter [31]. GoDaddy's mismatch with its own practice statement ran on the five-day clock under the current rules, and took nine [7] [8]. A ballot on the split entering discussion would settle the question.

## 2. Certificate Transparency

*Every publicly trusted web certificate must appear in public logs, and the browsers admit, monitor and retire the logs themselves. The system is midway through a move from its original design to a static, tiled one that can be served from ordinary storage.*

### Recent Developments

The eMudhra compromise turned the logs into a target. Once the keys were public, people used them to mint certificates and submit them to logs as proofs of concept [4]. By 25 October 107,107 such certificates had been logged on 20 and 21 October, 106,050 of them carrying a Google name [4]. On 20 October Cloudflare closed the submission interfaces of its Raio logs of the original design "to mitigate the eMudhra DoS vector" and asked Apple to reject the three affected shards [32]. Chrome had already moved them from pending to rejected [32].

Let’s Encrypt reported a policy breach of its own. Three of its logs, Twig, Sycamore and Willow, served stale checkpoints during six instance replacements of about 2.5 minutes each on 19 and 20 October [33]. One of those replacements deployed the Sunlight log software version that blocks the eMudhra keys [33]. The Chrome transparency team said on 21 October that Chrome policy had been violated [33]. The software’s author replied on 23 October that one-minute merge delays “are simply a mistake” and proposed a 24-hour limit with a rule that each checkpoint must include everything accepted before it [33].

Chrome’s log list reached version 95.11 on 24 October with no change to any log’s state since 14 October [34]. Its earlier movement was all growth. GoDaddy became a log operator when its five Aquamarine tiled logs qualified on 30 September, and sixteen more logs qualified on 13 and 14 October, from HARICA, Sectigo and Let’s Encrypt [34]. Apple’s list rejected fifteen shards covering the first half of 2026 on 5 October and has not changed since [35].

TrustAsia answered the complaints about its logs. On 18 October it hard-coded its block size [36]. On 24 October it said it will run no logs of the original design after its 2027 shards, keeping the current ones on security updates only [36]. The request that its logs say when a rejected client may retry was never addressed [36].

The most serious operational incident is still HARICA’s. Its new Selene logs missed their maximum merge delay on 12 October and again on 14 October [37]. Its preliminary report of 15 October does not identify the crash cause, because the server logs were missing [37]. The only reply since suggested dropping the scaling group that replaced the instance [37]. Earlier in the autumn Geomys, IPng Networks, GoDaddy and Microsec each reported shorter outages [38] [39] [40] [41].

## Current State

Both log designs are accepted, and neither is retired. Chrome admits logs built to the original RFC 6962 design or to the static specification [42] [43]. Since 15 April 2026 a certificate may carry timestamps from static logs alone [44]. Chrome will also stop accepting timestamps delivered through status responses in Chrome 148 [45].

Apple now states its terms for both designs. Its log program page, published 3 September 2026, accepts logs built to version 1.0.0 of the static specification as well as the original design [46]. Both kinds must meet 99% uptime [46]. An original-design log may take up to 24 hours to merge a certificate, while a static log may take at most one minute [46]. A question of 19 October on when Apple will publish a revised policy that drops the original design’s timestamps has drawn no reply [47].

Obligations on both sides are tightening. Chrome’s root program has required authorities to log every web server precertificate since 15 June 2026 [48]. From 1 November, every newly added log must publish a machine-readable record of its operational state, referenced from its operator’s record [42]. Chrome’s policy runs each log through the states pending, qualified, usable, read-only, retired and rejected [49].

Two operational questions are open. HARICA’s Selene logs remain qualified after their merge delay misses, and Chrome has posted no decision on the incident [34] [37]. Whether the static

logs' one-minute merge delay survives the Let's Encrypt incident is now a live policy question, raised by the software's own author [33].

## 3. Merkle Tree Certificates

*A Merkle Tree Certificate replaces the usual chain of signatures with a proof that the certificate appears in a signed public log. Transparency stops being a check after issuance and becomes part of issuance itself.*

### Recent Developments

The design's specifications moved quickly. Version 06 of the IETF draft appeared on 21 September, with authors from Google, Apple, Cloudflare and Geomys [50]. Version 07 followed on 7 October, and no newer revision had appeared by 25 October [50]. The same day, the C2SP project tagged the family of log specifications the design rests on, with the Merkle certificate log specification at version 0.1.0 [51]. That family covers tiles, mirrors, cosignatures, checkpoints and witnesses [51].

Chrome pinned its testing program to the new text on 16 October [52]. New requests to act as a cosigner must follow version 07 [52]. Chrome keeps version 05 working for a time, drops version 06, and fixes the tiles and mirror specifications at version 0.1.0 [52].

Issuers are building to it. Let's Encrypt's issuance software is landing code for Merkle certificate trees, including reading checkpoints from tiles and, on 24 October, the use of relative object identifiers [6]. Cloudflare says its planned authority will run mirroring cosigners and a new family of static transparency logs [53]. Chrome's testing program already requires every participant to operate both a log and a mirror [54].

### Current State

None of this is yet a production requirement. Chrome plans the production phase of its quantum-resistant program for 2027 [54]. Cloudflare has published nothing newer on Merkle certificates since its 29 September announcement [53]. Part 4 covers the root program policies that will decide which of these authorities browsers trust.

## Sources


1. Bug 2083449, eMudhra intermediate CA private key compromise - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2083449 - as of 2026-10-25
2. Protecting Chrome and Android users from compromised eMudhra intermediate CA certificates - Google Security Blog - https://blog.google/security/protecting-chrome-and-android-users-from-compromised-emudhra-intermediate-ca-certificates/ - as of 2026-10-25
3. Protecting Firefox users following the compromise of eMudhra intermediate certificates - Mozilla Security Blog - https://blog.mozilla.org/security/2026/10/20/protecting-firefox-users-following-the-compromise-of-emudhra-intermediate-certificates/ - as of 2026-10-25

4. eMudhra compromised intermediate CA private keys - mozilla dev-security-policy - https://groups.google.com/a/mozilla.org/g/dev-security-policy/c/0R3XLJL6FuE - as of 2026-10-25
5. Bug 2085612, eMudhra CRL and OCSP endpoints refusing common user agents - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2085612 - as of 2026-10-25
6. Boulder commits - letsencrypt/boulder - https://github.com/letsencrypt/boulder/commits/main.atom - as of 2026-10-25
7. Bug 2082703, GoDaddy certificate policy information mismatch - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2082703 - as of 2026-10-25
8. Bug 2083191, GoDaddy delayed revocation - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2083191 - as of 2026-10-25
9. Bug 2083502, DigiCert CRL number decreasing and late CRL publication - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2083502 - as of 2026-10-25
10. CA Certificate Compliance bugs opened from 17 October 2026 - Mozilla Bugzilla - https://bugzilla.mozilla.org/rest/bug?product=CA%20Program&component=CA%20Certificate%20Compliance&creation_time=2026-10-17&include_fields=id,summary,creation_time,status,whiteboard,creator - as of 2026-10-25
11. Bug 2084097, SHECA OCSP responder keys with public exponent 3 - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2084097 - as of 2026-10-25
12. Bug 2072663, GoDaddy delayed revocation of SHA-1 signed subordinate CA certificates - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2072663 - as of 2026-09-18
13. CA Certificate Compliance bugs opened from 12 September 2026 - Mozilla Bugzilla - https://bugzilla.mozilla.org/rest/bug?product=CA%20Program&component=CA%20Certificate%20Compliance&creation_time=2026-09-12 - as of 2026-09-26
14. CA Certificate Compliance bugs opened from 3 October 2026 - Mozilla Bugzilla - https://bugzilla.mozilla.org/rest/bug?product=CA%20Program&component=CA%20Certificate%20Compliance&creation_time=2026-10-03&include_fields=id,summary,creation_time,status,whiteboard - as of 2026-10-15
15. Chrome’s response to recent ccTLD registry hijacks - Google Security Blog - https://blog.google/security/chromes-response-to-recent-cctld-registry-hijacks/ - as of 2026-10-06
16. ccTLD registrar hijacks, certificate count - mozilla dev-security-policy - https://groups.google.com/a/mozilla.org/g/dev-security-policy/c/uTP46TjWem4 - as of 2026-10-07
17. Shortening certificate lifetimes to 64 days - Let’s Encrypt - https://letsencrypt.org/2026/10/07/64-day-certs - as of 2026-10-07
18. 64-day certificates on the classic profile in staging - Let’s Encrypt community API announcements - https://community.letsencrypt.org/t/252148 - as of 2026-10-14

19. OCSP Service Has Reached End of Life - Let’s Encrypt - https://letsencrypt.org/2025/08/06/ocsp-service-has-reached-end-of-life - as of 2025-08-06
20. OCSP deprecation - HARICA - https://news.harica.gr/article/ocsp-deprecation/ - as of 2026-01-29
21. RFC 9919, The Lightweight OCSP Profile for High-Volume Environments - IETF Datatracker - https://datatracker.ietf.org/doc/rfc9919/ - as of 2026-07-01
22. We Issued Our First Six Day Cert - Let’s Encrypt - https://letsencrypt.org/2025/02/20/first-short-lived-cert-issued - as of 2025-02-20
23. RFC 9773, ACME Renewal Information (ARI) Extension - IETF Datatracker - https://datatracker.ietf.org/doc/rfc9773/ - as of 2025-06-01
24. CRLite in production in Firefox - Mozilla Hacks - https://hacks.mozilla.org/2025/08/crlite-fast-private-and-comprehensive-certificate-revocation-checking-in-firefox/ - as of 2025-08-19
25. Pull request 288, Mass Revocation Template - mozilla/pkipolicy - https://github.com/mozilla/pkipolicy/pull/288 - as of 2026-09-23
26. Mass Revocation Template - mozilla/pkipolicy - https://raw.githubusercontent.com/mozilla/pkipolicy/master/rootstore/Mass-Revocation-Template.md - as of 2026-09-23
27. Bug 2055551, HARICA server TLS certificates with id-kp-clientAuth against CP/CPS - Mozilla Bugzilla - https://bugzilla.mozilla.org/show_bug.cgi?id=2055551 - as of 2026-07-20
28. Ballot SC-107 threads - servercert-wg list - https://groups.google.com/a/groups.cabforum.org/g/servercert-wg/search?q=SC-107 - as of 2026-10-25
29. Add section 6.1.3 for Delayed Revocation - mozilla/pkipolicy - https://github.com/mozilla/pkipolicy/commit/efa8ac40ac341fb813620938ef72328a53858038 - as of 2026-09-12
30. Responding to a misissuance, mass revocation requirements - MozillaWiki - https://wiki.mozilla.org/CA/Responding_To_A_Misissuance - as of 2025-09-01
31. Minutes of the F2F 65 meeting, Server Certificate Working Group - CA/Browser Forum - https://cabforum.org/2025/06/11/minutes-of-the-f2f-65-meeting-in-toronto-canada-scwg-june-11-2025/ - as of 2025-06-11
32. Raio RFC 6962 log shards closed to submissions - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/Xr0OqtDQplQ - as of 2026-10-25
33. Let’s Encrypt Twig, Sycamore and Willow stale checkpoints - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/fEm84uwtg9Y - as of 2026-10-25
34. Chrome Certificate Transparency log list, v3 - Google - https://www.gstatic.com/ct/log_list/v3/log_list.json - as of 2026-10-25
35. Apple Certificate Transparency log list - Apple - https://valid.apple.com/ct/log_list/current_log_list.json - as of 2026-10-25

36. TrustAsia log get-entries limits - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/glxX0b492wE - as of 2026-10-25
37. HARICA Selene MMD incident - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/vzYtSU2EKdQ - as of 2026-10-25
38. Tuscolo2026h2 write-path degradation - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/RcKh1_LxoB0 - as of 2026-09-17
39. IPng Networks log frontend incident - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/m5yFd5yhal4 - as of 2026-09-14
40. GoDaddy Aquamarine 2026h2 get-roots degradation - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/H2NA8-htebE - as of 2026-10-19
41. Microsec Eszigno log outage - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/w5Z-qWPIZj0 - as of 2026-10-02
42. Certificate Transparency Log Policy - Google Chrome - https://googlechrome.github.io/CertificateTransparency/log_policy.html - as of 2026-10-18
43. Chrome CT Policy changes to accept static-ct-api logs - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/HBFZHG0TCsY/m/HAaVRK6MAAAJ - as of 2026-04-01
44. Removal of the one-RFC6962-log requirement - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/IXPT4r1CPdE - as of 2025-12-01
45. Removal of OCSP-delivered SCTs in Chrome 148 - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/6ewCgspeyZE - as of 2026-03-20
46. Apple’s Certificate Transparency log program - Apple Support - https://support.apple.com/en-us/103703 - as of 2026-10-19
47. Question on the revised Apple CT policy - chromium ct-policy list - https://groups.google.com/a/chromium.org/g/ct-policy/c/9SMrMvEF1NM - as of 2026-10-25
48. Chrome Root Program Policy, Version 1.8 - Google Chrome - https://googlechrome.github.io/chromerootprogram/crp/policy - as of 2026-08-28
49. Certificate Transparency log states - GoogleChrome/CertificateTransparency - https://github.com/GoogleChrome/CertificateTransparency/blob/main/log_states.md - as of 2026-09-01
50. draft-ietf-plants-merkle-tree-certs - IETF Datatracker - https://datatracker.ietf.org/doc/draft-ietf-plants-merkle-tree-certs/ - as of 2026-10-25
51. C2SP commits from 2 October 2026 - GitHub - https://api.github.com/repos/C2SP/C2SP/commits?since=2026-10-02T00:00:00Z - as of 2026-10-07

52. Chrome Root Program commit 5f8d529, quantum-resistant root program testing FAQ - GitHub - https://api.github.com/repos/GoogleChrome/chromerootprogram/commits/5f8d529 - as of 2026-10-16
53. Building a post-quantum certificate authority with Merkle Tree Certificates - Cloudflare Blog - https://blog.cloudflare.com/pq-ca-with-mtcs/ - as of 2026-10-25
54. Chrome Quantum-resistant Root Program, MTC testing - Google Chrome - https://googlechrome.github.io/chromerootprogram/cqrp/testing - as of 2026-09-26